
Seguretat Informàtica (SI)

Anàlisi Forense

René Serral (forked from: Davide Careglio)

Alguna font: Jordi Nin, “Network Security”, Computer Security, 2014

Ton Rodriguez, “Anàlisi forense”, Computer Security, 2018

Temari

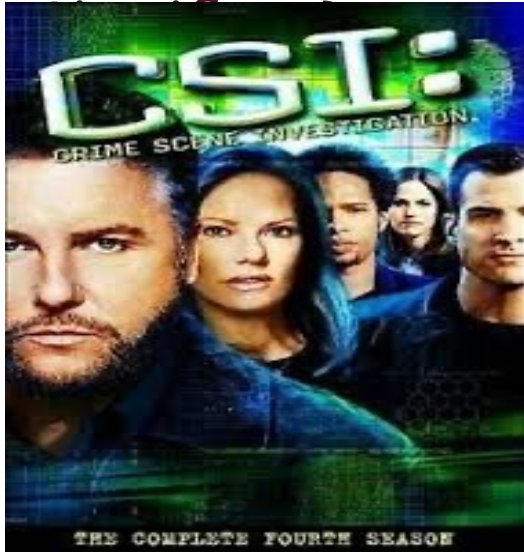
- Tema 1. Introducció
- Tema 2. Criptografia
- Tema 3. Infraestructura PKI
- Tema 4. Seguretat en les aplicacions
- Tema 5. Seguretat als sistemes operatius
- **Tema 6. Anàlisis forense**

Índex

- **Introducció**
- Aspectes legals
- Forensic Readiness
- Aspectes d'una investigació
- Adquisició d'evidències
- Artefactes
 - Windows
 - Linux

Introducció

- Anàlisi forense...



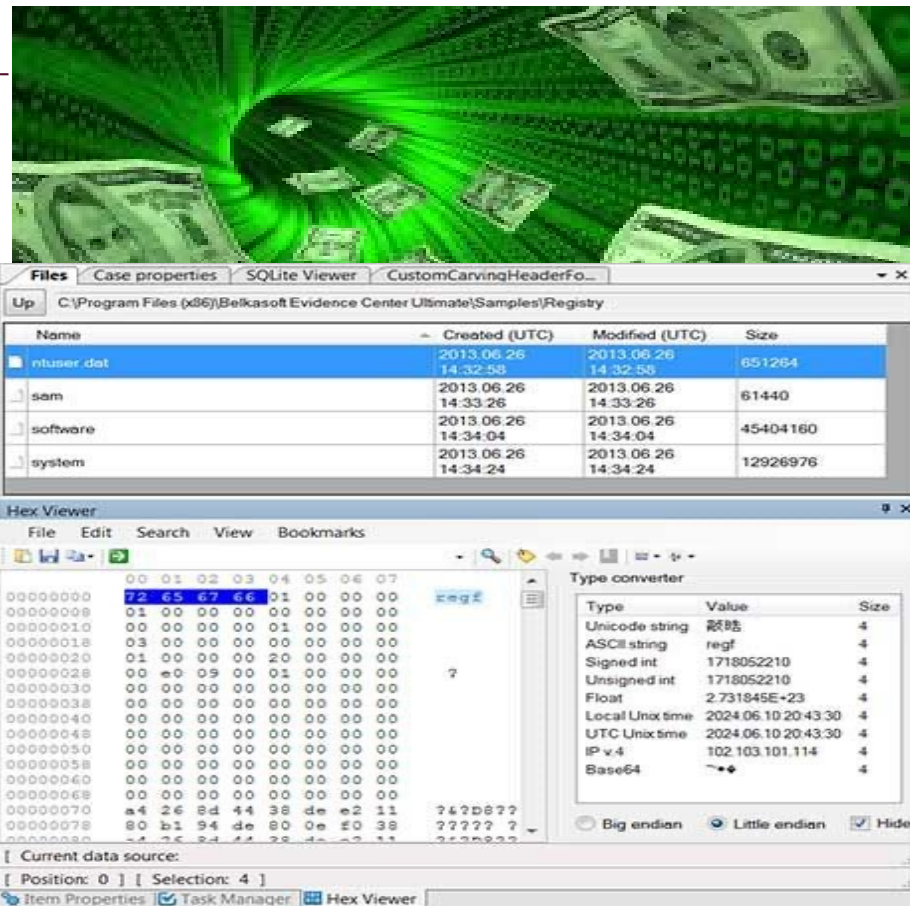
Introducció

- Anàlisi forense...
- Significat?
- I en l'entorn de ciberseguretat?
 - Anàlisi de hardware
 - Dades emmagatzemades
 - Software
 - Lleis específiques
 - Rastrear empremtes



Introducció

- Falta alguna cosa???
- Reconèixer que hi ha hagut un crim
- Trobar evidències del crim



Introducció

- La informàtica forense és l'aplicació, en l'àmbit IT, de tècniques científiques y analítiques especialitzades per a identificar, preservar, analitzar i presentar dades que siguin vàlides en un procés legal
- La "realització d'un forense" es basa en la **investigació d'un incident de seguretat** on intervé informació digital
- Els principals reptes d'aquesta investigació són:
 - Les evidències digitals són complexes
 - La objectivitat i coneixements dels jutges i pèrits
 - La manca d'estandardització de les eines
 - És un art o és una ciència?

Introducció: Incident de seguretat

- Event advers en el que algun aspecte de la seguretat de l'ordinador pot estar amenaçat
 - Pèrdua de confidencialitat o integritat de les dades
 - Interrupció del sistema
 - Interrupció o denegació del servei disponible
- Antigament: hackers
- Actualitat: mafies o cibercriminals
 - Atacs externs i interns
 - Robatori d'informació
 - Espionatge (propietat intel·lectual)
 - Denegació de servei (competència)
 - Trojans, virus, phishing, etc.

Introducció: el primer atac

- Al 1988 hi havia unes 60.000 màquines connectades a Internet sense preocupacions per la seguretat
- El 2 de novembre de 1988 apareix un worm creat per l'estudiant Robert T. Morris com un experiment que utilitzava un defecte de Unix per a reproduir-se fins bloquejar l'ordinador
- La fiscalia va argumentar que no es tractava d'un error sinó d'un atac contra el govern dels Estats Units
- Se'l va condemnar a 3 anys de llibertat condicional, \$14,000 de multa i 400 horas de servei a la comunitat

Introducció: els primers CERTs

- A desembre de 1988, arrel de l'incident amb Morris, es crea el Computer Emergency Response Team Coordination Center (CERT/CC) a la Universitat Carnegie Mellon, www.cert.org
- Team d'experts en seguretat informàtica amb l'objectiu de respondre de forma òptima davant d'una incidència on hi hagi informació digital
- També es coneixen com
 - Computer Emergency Readiness Team
 - Computer Security Incident Response Team (CSIRT)

Introducció: els primers CERTs

- A 1992 es crea el primer equip de resposta a incidents europeu, el SURFnet-CERT holandès
- A finals de 1994, Manel Medina (UPC) crea esCERT-UPC (inclòs a inLab)
- I a Espanya?
 - Al 1995 es crea IRIS-CERT a la comunitat RedIRIS
<https://www.rediris.es/cert/>
 - Al 2006, el CCN-CERT adscrit al CNI
<https://www.ccn-cert.cni.es>
 - Al 2014, l'INCIBE-CERT adscrit al Ministeri d'Economia i Empresa
<https://www.incibe-cert.es>

Índex

- Introducció
- **Aspectes legals**
- Forensic Readiness
- Aspects d'una investigació
- Adquisició d'evidències
- Artefactes
 - Windows
 - Linux

Aspectes legals

- Es sol realitzar un anàlisi forense per a
 - Determinar activitats que es suposen delictives o il·legítimes
 - Obtenir proves simplement a títol informatiu per a coneixement exclusiu del client
- És important conèixer la legislació per evitar el rebuig de proves en un judici per haver infringit la llei
 - Una prova és l'instrument que tenen les parts per a acreditar els fets en els que basen les seves pretensions
 - El moment de presentació de les proves depenen de la jurisdicció
 - Civil, Laboral o Social, Penal, Contenciosa Administrativa

Aspectos legales: Jurisdicción civil

- Està regulada per la Llei de l'Enjudiciament Civil
 - <https://www.boe.es/buscar/act.php?id=BOE-A-2000-323>
- Proves pericials
 - De part (s'adjunten a la demanda o resposta)
 - Judicials (les poden demanar les parts abans de la vista)
- Àmbits majoritaris d'actuació
 - Demostració de danys en equips informàtics
 - Demostració de competència deslleial
 - Identificació de subjectes que hagin comès un il·lícit civil
- Àrees especialitzades
 - Mercantil/comercial
 - Familiar

Aspectes legals: Jurisdicció laboral o social

- Està regulada per la Llei de Procediment Laboral
 - <https://www.boe.es/buscar/act.php?id=BOE-A-1995-8758>
- Àmbit d'actuació
 - Obtenció d'informació sobre el ús correcte o incorrecte per part dels treballadors dels medis telemàtics titularitat de l'empresari
- Àrees especialitzades
 - Relacions laborals entre les parts (denunciant i denunciada)
- Es limita la capacitat de control de l'empresari en favor dels drets fonamentals dels treballadors

Aspectes legals: Empresaris vs treballadors

- Obtenció de proves:
 - El registre d'equips informàtics es realitzarà en horari laboral, dins dels locals de la empresa i en presència d'un representant dels treballadors

Art. 90.1 Llei de Procediment Laboral	Art. 20.3 Estatut dels Treballadors
Les parts podran valdre's de tots els mitjans de prova que estiguin regulats per la Llei, admetent com a tals els medis mecànics de reproducció de la paraula, de la imatge i del so, a no ser que s'haguessin obtingut, directa o indirectament, mitjançant procediments que suposin violació de drets fonamentals o llibertats públiques	L'empresari podrà adoptar les mesures que estimi més oportunes de vigilància i control per a verificar el compliment per al treballador de les seves obligacions i deures laborals, guardant en la seva adopció i aplicació la consideració deguda a la seva dignitat humana i tenint en compte la capacitat real dels treballadors disminuïts, en el seu cas

Aspectos legales: Jurisdicció penal

- Està regulada per la Lley de l'Enjudiciament Criminal
 - <https://www.boe.es/buscar/act.php?id=BOE-A-2018-18821-3036>
- Àmbit d'actuació
 - Aportar proves sobre suposats delictes o faltes
 - La validesa d'aquestes proves requerirà, en molts casos, la col·laboració en òrgans judicials (jutges d'instrucció) a l'hora d'obtenir les evidències
- Fases del procediment
 - Instrucció
 - Enjudiciament
- **Llei Orgànica de protecció de la seguretat ciutadana (2015)**

Aspectes legals: Contenciosos administratius

- Àmbit d'actuació:
 - Litigis de particulars i empreses contra les Administracions públiques (Estat, Comunitats Autònomes i Entitats Locals)
 - Tota classe de ens públics (Agència de protecció de dades, Servei de Salut d'una Comunitat Autònoma, Universitats públiques, etcètera)

Aspectes legals: Lleis específiques sobre SI

- Codi de Dret de la Ciberseguretat

- [Link al ROF](#)

Aprobado el Real Decreto-ley en materia de administración electrónica, contratación de las administraciones públicas y telecomunicaciones.

Jueves 31 de octubre de 2019

- El **Decreto-ley que permite al Gobierno intervenir en Internet** **De 'blockchain' a ciberseguridad: 6 claves del Real Decreto-ley que permite al Gobierno intervenir en Internet** **Es sària la**

6. Administración de ciberseguridad: Se modifica el Real Decreto Legislativo 12/2018 que transponía en España la Directiva NIS (seguridad de las redes y sistemas de información), para llenar un espacio que no había sido regulado inicialmente, y es la atribución de la coordinación técnica en los ciberincidentes que afecten a Administraciones Públicas al CCN (Centro Criptológico Nacional, organismo del CNI).

Índex

- Introducció
- Aspectes legals
- **Forensic Readiness**
- Aspectes d'una investigació
- Adquisició d'evidències
- Artefactes
 - Windows
 - Linux

Motivació

- Investigació forense d'una evidència digital
 - Resposta a un incident de seguretat o crim relacionat amb ordinadors
- Seria interessant tenir la capacitat de
 - Llegir/analitzar dades constantment per a determinar si hi ha un atac, s'està cometent un crim, s'està fent un mal ús dels recursos, etc.
 - Saber preservar les evidències digitals abans, durant i després de la ocurrència de l'incident

Forensic Readiness: Definició

- “Una organització ha de tenir un nivell apropiat de capacitat per a poder preservar, recopilar, protegir i analitzar evidències digitals per a que aquestes evidències poden ser utilitzades efectivament: en qualsevol assumpte legal; en investigacions de seguretat; en procediments disciplinaris; en un tribunal laboral; o en un tribunal de justícia.”¹
- L'ús de les evidències digitals com defensa requereix
 - Monitorització de sistemes i usuaris: arxius de registre, correu electrònic, tràfic de xarxa, trucades telefòniques, etc.
 - Medis (tècnics, físics i procedimentals) per a assegurar les dades amb els estàndards d'admissibilitat

Forensic Readiness: Escenaris

- Amenaces i extorsió
- Compromí de la informació
- Accidents i negligències
- Disputes comercials
- Desacords, enganys i males pràctiques
- Delinqüència econòmica (p.ex. Blanqueig de diners)
- Abús de contingut
- Invasió de la privacitat i robatori de la identitat
- Qüestions disciplinàries dels empleats
- Etc.

Beneficis

- Possible defensa a una demanda judicial
- Element de dissuasió de les amenaces internes
- Interrupció mínima del negoci
- Reducció de costos d'investigació
- Reducció de costos de divulgació (per exemple, conformitat amb la LOPD)
- Mostra una diligència corporativa davant els actius d'informació de la empresa
- Demostra el compliment de reglamentacions
- Suport a possibles sancions a treballadors

Fonts

- On es generen les dades?
- En quin format estan emmagatzemades?
- Quan temps s'emmagatzemen i per què?
- Com es gestionen, es controlen i es processen?
- Qui té accés a les dades?
- Quantes dades es produeixen?
- Qui és el responsable d'aquestes dades?
- Com es podrien utilitzar en una investigació?
- Contenen informació personal?
- etc.

Requeriments

- Coneixement de la seguretat de l'entorn
 - Inventari d'actius
 - Avisos de vulnerabilitats
 - Anàlisi del risc
- Monitoratge
 - Panels de control
 - Detecció d'intrusions: NIDS ([Snort](#)) i HIDS ([OSSEC](#))
 - Correlació d'events: Security information i Event management ([Wazuh](#))
- Eines de gestió d'incidents
 - Correu electrònic i formularis
 - Filtrat i prioritització
 - Base de dades de coneixement

Índex

- Introducció
- Aspectes legals
- Forensic Readiness
- **Aspectes d'una investigació**
- Adquisició d'evidències
- Artefactes
 - Windows
 - Linux

Com s'inicia una investigació

- Les investigacions forenses se solen iniciar
 - A partir d'una ordre judicial quan les forces de l'ordre tenen indicis d'algun delictes
 - Es necessita per a que el jutjat admeti les evidències
 - Per aplicació d'una política de seguretat de l'empresa que permeti que es realitzi
 - Banners, cursos de conscienciació, entrega de documents en paper de lectura obligada
 - Firma de la documentació conforme s'ha sigut informat sobre les conseqüències d'incomplir la política de seguretat
- Si no es cap dels casos anteriors, es pot començar previ consentiment voluntari de les parts implicades

Inici d'un procés

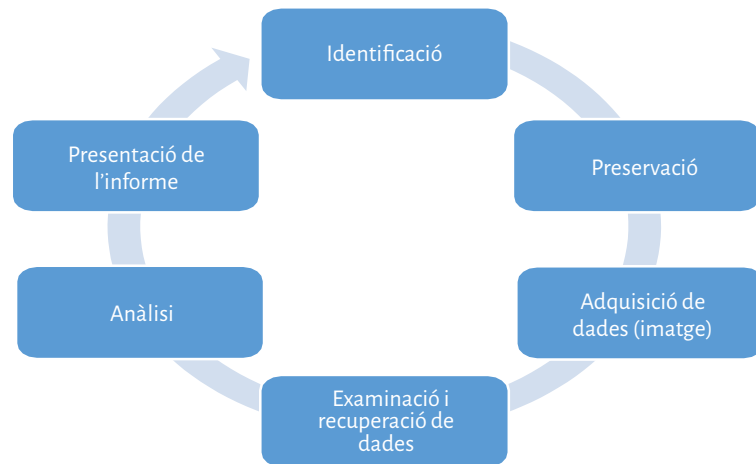
- Procediments civils, mercantils o laborals
 - Demanda
- Procediments penals (per delictes o faltes)
 - Denuncia
 - No tenim per què ser víctimes
 - Es realitza de forma oral o escrita, davant la policia o el jutjat
 - Querella
 - Sempre soms la part perjudicada
 - Es denuncia a una persona concreta
 - Es realitza per escrit a un jutjat
 - S'han aportar proves que demostrin el fet denunciat
 - Es necessita un advocat i un procurador
- "Diferència entre demanda, denuncia i querella"

Bones pràctiques

- Documentació exhaustiva
 - Preservació de les evidències
- Formació continua
 - Realització de cursos sobre anàlisis forense
 - Estudi de noves tècniques i eines
 - Recursos web i revistes especialitzades
 - European Network of Forensic Science Institutes, <http://enfsi.eu>
- Conducta professional
 - Integritat
 - Confidencialitat
 - Ètica
 - Moral

Metodologia: 6 fases

- **Identificació** de l'escenari
 - Avaluació del cas
- **Preservació**
 - Documentació i cerca de les evidències
- **Adquisició** o recuperació de dades
- **Examinació**
 - Agregació i obtenció d'informació rellevant, arxius eliminats, etc.
- **Anàlisi** en un entorn de laboratori
- **Presentació**
 - Elaboració d'un informe i la seva presentació



Pas 1: Identificació de l'escenari

- L'avaluació del cas implica acotar l'entorn en el que s'ha produït
 - Tipus d'evidència involucrada
 - Sistemes operatius i software involucrats
 - Format dels sistemes de fitxers
 - Localització de la evidència
 - Motivo de la sospita
- És molt important
 - Tenir professionals amb els coneixements adequats
 - Disposar d'un laboratori forense
 - Disposar de materials apropiats per a recollir i processar les evidències

Pas 2: Preservació

- La metodologia de recollecció i preservació de les evidències implica documentar exhaustivament
 - L'escenari
 - El mètode d'obtenció de la evidència
 - La cadena de custòdia
 - El hardware i la configuració del sistema
 - La hora i data del sistema
 - Les dates i hores clau dels successos
 - Etcètera

Pas 3: Adquisició

- "Una evidència sense metodologia no és una prova"
- Localitzar la evidència
- Assegurar l'escenari
- Descobrir dades rellevants
- Preparar l'ordre de volatilitat (de major a menor)
 - Ordenar la informació segons la seva disponibilitat en el temps
- Recollir la evidència
 - Recuperació d'informació esborrada o oculta
 - Duplicat de la evidència (bit a bit)
- Preparar la cadena de custòdia

Pas 4: Examinació

- Agregar la informació rellevant obtinguda anteriorment
- Filtrar la informació
 - Paraules clau
 - Informació temporal
- Obtenir les dades rellevants
 - De la informació obtinguda, treure la part important per a la investigació
 - Per exemple, extraure la bústia d'un usuari d'una base de dades

Pas 5: Anàlisi

- Anàlisi en un entorn de laboratori
 - S'utilitza una còpia de la evidència
 - Utilització d'eines forenses
- Analitzar el coneixement extret de les dades ja processades
 - Respectant la legalitat
 - Investigant únicament allò pel que estem autoritzats

Pas 6: Presentació

- Expressar a un document els fets
 - Contrastats
 - Relacionats amb la investigació
- No incloure dades subjectives
 - Si s'expressa una hipòtesi, comentar-la clarament
- L'informe ha d'incloure el treball realitzat i els resultats obtinguts
 - S'inclourà el què, quan, com i on
 - No s'inclou el per què
 - Les troballes han de ser reproduïbles

Resum

- Vídeo de Guidance Software
- <https://www.youtube.com/watch?v=Xo6El8c3qrU>

Índex

- Introducció
- Aspectes legals
- Forensic Readiness
- Aspectes d'una investigació
- **Adquisició d'evidències**
- Artefactes
 - Windows
 - Linux

Tasques d'un investigador

- Identificar el crim
- Obtenir la evidència del mateix
- Mantenir la cadena de custòdia
- Realitzar un anàlisi forense
- Presentar la evidència
- Testificar

consultoria

adquisició

agregació

anàlisi

informes

Laboratori

Avaluació

- La evidència digital ha de ser avaluada en funció de l'abast de cada cas
 - Revisar l'ordre de registre o qualsevol altra autorització legal
 - Discutir amb l'investigador principal que es pot o no descobrir mitjançant la realització del forense
 - Estudiar la possibilitat d'obtenir altres evidències
 - p. ex. Enviament d'una ordre de preservació de dades a un ISP
 - Considerar la rellevància dels perifèrics al cas
 - p. ex. Robatori o frau: targetes de crèdit en blanc, paper de xecs, impressores, escàners, etc.
 - Determinar si hi ha informació addicional al cas
 - p. ex. Comptes de correu, ISP, usuaris, ajustos de xarxa, etc.

Adquisició d'evidències: La “escena del crim”

- Accions habituals quan s'investiga l'“escena del crim”
 - Identificar el número i tipus d'ordinadors
 - Determinar si hi ha una xarxa present
 - Entrevistar a l'administrador de sistemes i els usuaris
 - Identificar i documentar els tipus i volums de dades, incloent medis extraïbles
 - Identificar àrees d'emmagatzematge extern
 - Identificar software propietari
 - etc.

Cadena de custodia

- Cada evidència precisa d'un document de cadena de custodia
 - Evidència inequívocament identificada
 - Informació sobre qui custodia la evidència
 - Informació sobre cada canvi de custodia (data, hora, personal involucrat)
- El document de cadena de custodia ha d'estar sempre en el mateix lloc que la evidència
- Aquest document assegura la integritat de la evidència com prova davant processos judicials

Exemple de formulari

Computer Evidence Chain of Custody		(Place Barcode ID label here)
Evidence Description		
Media Description: ☒ Hard Drive ☐ USB Key ☐ CD/DVD ☐ Other (Describe):		
Manufacturer:		Model: Serial #:
Content Description:		
Collection Method:		
Date/Time Acquired:	Collector (print full name):	Signature:

Copy History

New Item #	Copy Date	Copied by	Method	Disposition of Original

Transfer History

Date/Time	Transfer From	Signature	Transfer To	Signature

Ordre d'adquisició

- Basat en diferents guies de recollecció i arxivat d'evidències electròniques
 - RFC3227
- Ordre de volatilitat
 - Registres i caché del processador
 - Taula de rutes i caché ARP
 - Memòria RAM de la màquina
 - Directoris temporals del sistema de fitxers
 - Disc físic
 - etc.
- La pregunta del milió: quan s'ha d'apagar una màquina?

Offline vs Live

- Adquisició de tipus "Offline"
 - Evita canvis degut a l'ús normal de l'equip
 - Apagar l'equip, treure el disc i col·locar-lo en una estació forense
 - Utilitzar un dispositiu hardware / software para bloquejar les escriptures (només lectura) abans de crear la imatge
- Adquisició de tipus "Live" (en calent)
 - Quan no es pugui apagar l'equipo, per exemple:
 - L'equip utilitza encriptació de disc i no es té accés a les claus necessàries per a desxifrar
 - S'ha de mantenir el servei per motius de negoci
 - No es vol apagar l'equipo per a no modificar el comportament d'un procés maliciós
 - No es volen perdre dades volàtils

Bones pràctiques en la preservació

- Documentar el hardware / software utilitzats
- Obrir l'ordinador per a tenir accés físic als discos
 - Protegir-los d'electricitat estàtica i camps magnètics
 - Documentar aquesta acció i realitzar-la davant testimonis
- Identificar els dispositius d'emmagatzematge (interns o externs) que és necessari adquirir
- Documentar els dispositius d'emmagatzematge interns i la configuració hardware de l'equip
 - Estat del disc (marca, model, geometria, interfície, etc.)
 - Components interns (targetes de so, gràfiques, de xarxa, etc.)

Bones pràctiques en la preservació dels discos

- Comprovar si està xifrat abans d'apagar l'equip
 - Es recomana obtenir les dades en calent (live)
- Desconnectar per a prevenir la destrucció o alteració de les dades
- Realitzar l'adquisició utilitzant l'equip de l'examinador
- És aconsellable l'ús de dispositius de protecció d'escriptura per evitar modificar el disc original
- El disc destí ha d'estar "net" en termes forenses
 - Disc nou recentment estrenat
 - Disc utilitzant el format indicant el procediment

Bones pràctiques en la preservació dels discos

- És recomanable garantir la integritat de la evidència original abans d'adquirir-la
 - Càlcul d'un hash del disc (p.ej. SHA-256)
- Adquirir la evidència utilitzant software o hardware testejat i verificar la adquisició de dades
 - Realitzar la còpia assegurant copiar els fitxers esborrats i els [file slack](#)
 - Comparació del hash original respecte al de la còpia
- Xifrar las imatges forenses per a garantir la confidencialitat i establir la cadena de custòdia correcta per a la imatge
- Investigar sempre sobre les còpies

Adquisició d'evidències: Imatge d'un disc (clon)

- És una còpia "bit a bit" d'un disc complet o d'una partició del mateix
 - És una instantània estàtica (snapshot) del contingut de disc en un moment determinat
 - No es copien fitxers, es copien blocs del disc
 - Fitxers accessibles actualment
 - Espai d'slack (espai no utilitzat d'un clúster)
 - Espai no assignat
 - Fitxers esborrats, fragments d'arxius, dades ocultes
 - Preserven l'estat del disc en un moment determinat
 - És important utilitzar correctament les tècniques d'adquisició per a no invalidar la evidència

Adquisició d'evidències: Imatge forense

- Fitxers que contenen una imatge de disc
 - dd, ISO, RAW, QCOW2
 - **Sense compressió**: mateixa mida que la font original
 - **Comprimides**: per a estalviar espai
 - **Dividides** (split imatges): per a facilitar el transport
 - **Embedded**: contenen metadades sobre la imatge
 - Segell de temps amb la data de creació de la imatge
 - Hash criptogràfic que serveix com a empremta dactilar de la imatge
- No és el mateix que un clon
 - <https://glider.es/el-clonado-ya-no-se-lleva-parte-i/>
 - Un clon és un duplicat exacte bit-a-bit en un altre disc
 - Per a realitzar un clon es necessita
 - Mateix tipus de disc dur (tipus, mida, sectors, ...)
 - Disc «wipejat» (tots els bits a 0 per a evitar contaminacions)

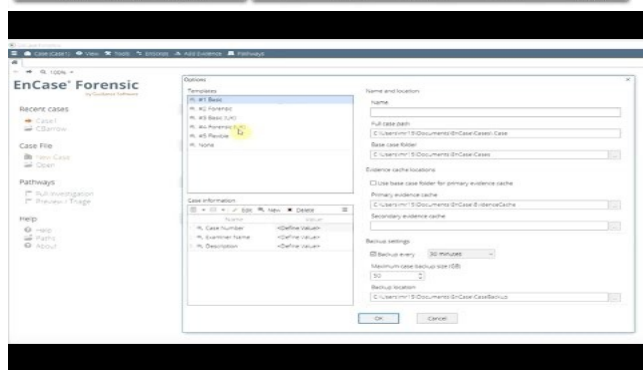
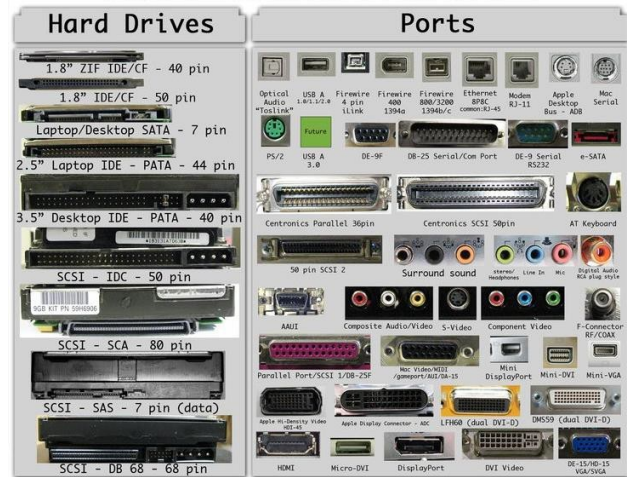
Característiques del Laboratori forense

- Mida i ubicació en funció del volum de treball i el tipus d'evidències que es tractaran
- Lloc segur amb vigilància i, a ser possible, amb una única entrada
 - Es registraran els accessos al laboratori, a les evidències, el material informàtic que entra i surt, etc.
- Sistemes de seguretat (caixes fortes, alarmes, etc.), protecció contra incendis i falta d'electricitat (UPS)
- Àrees de treball sense exposició a l'exterior (finestres)
- Estacions de treball offline per a anàlisis d'evidències
- Estacions de treball online per a consulta de documentació

Material forense

- Hardware
 - Cables i discos durs
 - Targetes gràfiques
 - Adaptadors o docks
 - etc.
- Software
 - Diferents SO
 - Comercial: EnCase, Cellebrite
 - Codi obert: SIFT, CAINE, etc.
 - Software ofimàtic (per a informes)
 - etc.

COMPUTER HARDWARE CHART



Característiques i requisits de les eines forenses

- **Preservació d'evidències**
 - Bloqueig lògic d'escriptura als discos originals
 - Soport de formats RAW, Encase EWF, AFF, etc.
 - Traçabilitat (cadena de custòdia)
 - Càlcul de hash criptogràfics
- **Reducció i selecció de dades ràpida**
 - Detecció de signatures d'arxius
 - Filtres avançats i motor de cerca

Característiques i requisits de les eines forenses

- Reconstrucció de volums i sistemes d'arxius
 - Detecció i muntatge de particions
 - Suport de formato VMDK
 - Suport de FAT12 / 16/32 (USB)
 - Suport de NTFS amb [ADS](#) y compressió (Windows)
 - Suport de HFS, HFS + y HFSX (OS X, iPhone)
 - Suport de Ext2/3/4 (GNU Linux, Android)
- Anàlisi multimèdia
 - Visualització de galeries de fotos
 - Extracció de miniatures de vídeos
 - Extracció de metadades EXIF

Característiques i requisits de les eines forenses

- Anàlisi d'artefactes Linux/Windows
 - Arxius/Fitxers
 - Registres
 - Bústies (p.e., PST a Outlook)
- Anàlisi de memòria
 - <http://www.primalsecurity.net/memory-forensics/>
 - Volatility Framework, <https://www.volatilityfoundation.org>
 - Rekall, <http://www.rekall-forensic.com>
 - Reconstrucció gràfica de processos: pstree, psxview,
 - Informació de processos: procdump
- Anàlisi de documents
 - Visualitzadors dedicats: PDF, Text, Web, etc.
 - Extracció de metadades, text i imatges a documents ofimàtics

Forensics software

- SIFT (SANS Investigative Forensic Toolkit)
 - <https://www.sans.org/tools/sift-workstation/>
 - Ubuntu 20.04 LTS x64
- CAINE (Computer Aided INvestigative Environment)
 - <https://www.caine-live.net>
 - v11.0 “Wormhole” – Ubuntu 18.04 x64
- ProDiscover Forensic
 - <https://www.prodiscover.com>
 - Windows, Mac, Linux
- WinFE (Windows Forensics Environment)
 - <https://www.winfex.net/home>
- BitCurator (University of North Carolina)
 - <http://bitcurator.net>
 - v2.0.10 – Ubuntu x64
- Sleuth Kit + Autopsy
 - <https://www.sleuthkit.org>

Índex

- Introducció
- Aspectes legals
- Forensic Readiness
- Aspectes d'una investigació
- Adquisició d'evidències
- Artefactes
 - **Windows**
 - Linux

Artefactes Windows: Directorio del sistema

- La ubicació del directori del sistema depèn de la versió del SO
- Habitualment el disc del sistema sol tenir assignada la lletra C: (variable %HOMEDRIVE%)

Directori de Sistema	Sistema Operatiu
%HOMEDRIVE%\WINNT	Windows NT Windows 2000
%HOMEDRIVE%\Windows	Windows 95/98/ME Windows XP/2003 Windows Vista Windows 7 Windows 2008 Windows 8/8.1 Windows 2012 Windows 10

Artefactes Windows: Directori del perfil de l'usuari

- La ubicació del directori del perfil de l'usuari també depèn de la versió del SO
- Variable %USERPROFILE%)

Directori del perfil de l'usuari	Sistema Operatiu
N/A	Windows 95/98/ME
%HOMEDRIVE%\WINNT\Profiles	Windows NT
%HOMEDRIVE%\Document and Settings	Windows 2000 Windows XP/2003
%HOMEDRIVE%\Users	Windows Vista Windows 7 Windows 2008 Windows 8/8.1 Windows 2012 Windows 10

Artefactes Windows: User Shell Folders

- Habitualment al directori del perfil de l'usuari
- Es poden canviar la seva ubicació, definida al registre
 - `HKEY_CURRENT_USER\Software\Microsoft\Windows\ CurrentVersion\Explorer\User Shell Folders`
- Es poden utilitzar dreceres per accedir
- Alguns dels més importants són:
 - L'escriptori
 - Documents
 - Local AppData
 - Favorits (Accessos directes d'Internet Explorer)
 - Descàrregues
 - AppData (Itinerància)

Artefactes Windows: Directoris interessants

- Arxius recents (Recent)
 - Cada cop que s'obre un fitxer, es crea un fitxer LNK
 - %APPDATA%\Microsoft\Windows\Recent
- Directori temporal
 - Utilitzat per moltes aplicacions i installadors
 - Solen quedar “restes” que es poden analitzar
 - %LOCALAPPDATA%\Temp
- Directoris utilitzats per els browsers
 - Preferits
 - Històric de navegació
 - Cookies
- Paperera

Artefactes Windows: Accessos directes (LNK)

- File Shortcuts o Shell Links
 - Arxius locals que apunten a recursos locals o remots
 - Creats per usuaris o instal·ladors (habitualment)
 - Creats automàticament a l'obrir un fitxer
 - El llistat d'«arxius recents» utilitza aquest tipus d'enllaços
- Permeten conèixer els detalls de l'arxiu original
 - Carpeta original on es troba l'arxiu
 - Dates d'accés o marques de temps
 - Informació del volum, número de sèrie, nom NetBIOS i adreça MAC de l'ordinador on es troba
 - Detalls de xarxa si és un arxiu remot
 - Mida de l'arxiu

Artefactes Windows: Exemple de LNK

- Accés recent a documents/arxius
 - %APPDATA%\Microsoft\Windows\Recent
 - C:\Users\<usuari>\AppData\Roaming

```
Offset(h) 00 01 02 03 04 05 06 07 08 09 0A 0B 0C 0D 0E 0F 10 11 12 13 14 15 16 17 18 19 1A 1B 1C 1D 1E 1F
00000000 4C 00 00 00 01 14 02 00 00 00 00 00 00 00 00 00 46 93 00 20 00 80 00 00 00 06 F8 78 B8 L.....À.....F". .E....sx,
00000020 B4 B1 D1 01 06 F8 78 B8 B4 B1 D1 01 00 75 27 4A 36 F2 D0 01 EC 0D 00 00 00 00 00 01 00 00 00 ±N..sx,±N..u'J6cD.i.....
00000040 00 00 00 00 00 00 00 00 00 00 00 00 DB 01 14 00 1F 50 E0 4F D0 20 EA 3A 69 10 A2 D8 08 00 2B 30 .....Û....PaOd è:i.c0..+0
00000060 30 9D 19 00 2F 44 3A 5C 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 0.../D:\.....T.1..
00000080 00 00 00 4E 47 8E 53 10 00 45 51 55 49 50 53 00 00 3E 00 09 00 04 00 EF BE 94 46 EC 7E 4E 47 8E ...NGZs..EQUIPS..>.....iM"Fi-NGZ
000000A0 53 2E 00 00 00 23 00 00 00 00 00 01 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 S...#. ....F.U.E
000000C0 00 51 00 55 00 49 00 50 00 53 00 00 00 16 00 4A 00 31 00 00 00 00 00 B3 48 10 4F 10 00 56 4D 73 .Q.U.I.P.S...J.1.....H.O.VMs
000000E0 00 38 00 09 00 04 00 EF BE 94 46 EC 7E B3 48 10 4F 2E 00 00 00 24 00 00 00 00 01 00 00 00 00 .8.....iM"Fi~H.O.....S.
00000100 00 00 00 00 00 00 00 00 00 00 00 00 6F 46 25 00 56 00 4D 00 73 00 00 00 12 00 8C 00 31 00 00 00 00 .O.F%.V.M.s....G.1....
00000120 00 32 47 A2 8A 10 00 46 4F 52 35 37 32 7E 31 2E 56 4D 57 00 00 70 00 09 00 04 00 EF BE B3 48 10 .2GcŠ..FOR572~1.VMW..p.....iM"H.
00000140 4F B3 48 1A 4F 2E 00 00 00 7B 05 00 00 00 00 5E 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 O"H.O.....
00000160 00 00 00 46 00 4F 00 52 00 35 00 37 00 32 00 20 00 58 00 70 00 6C 00 69 00 63 00 6F 00 2D 00 4C ...F.O.R.S.7.2. .X.p.l.i.c.o.-L
00000180 00 6F 00 67 00 73 00 74 00 61 00 73 00 68 00 2E 00 76 00 6D 00 77 00 61 00 72 00 65 00 76 00 6D ...o.g.s.t.a.s.h...v.m.w.a.r.e.v.m
000001A0 00 00 00 1C 00 82 00 32 00 EC 0D 00 00 32 47 89 8A 80 00 46 4F 52 35 37 32 7E 31 2E 56 4D 58 00 .....2.i...2GkŠE.FOR572~1.VMX.
000001C0 00 66 00 09 00 04 00 EF BE B3 48 10 4F B3 48 10 4F 2E 00 00 AF 05 00 00 00 3B 00 00 00 00 .f.....iM"H.O.....
000001E0 00 00 00 00 00 00 00 00 00 00 00 00 00 00 46 00 4F 00 52 00 35 00 37 00 32 00 20 00 58 00 70 .....F.O.R.S.7.2. .X.p
00000200 00 6C 00 69 00 63 00 6F 00 2D 00 4C 00 6F 00 67 00 73 00 74 00 61 00 73 00 68 00 2E 00 76 00 6D .l.i.c.o.-L.o.g.s.t.a.s.h...v.m
00000220 00 78 00 00 00 1C 00 00 00 7C 00 00 00 1C 00 00 00 01 00 00 1C 00 00 00 32 00 00 00 00 00 00 .X.....|.....2.....
00000240 00 7B 00 00 00 16 00 00 00 03 00 00 00 FC 99 E5 52 10 00 00 00 44 41 44 45 53 00 44 3A 5C 45 51 .{.....ù"AR....DADES.D:\EQ
00000260 55 49 50 53 5C 56 4D 73 5C 46 4F 52 35 37 32 20 58 70 6C 69 63 6F 2D 4C 6F 67 73 74 61 73 68 2E UIPS\VMs\FOR572 Xplico-Logstash.
00000280 76 6D 77 61 72 65 76 6D 5C 46 4F 52 35 37 32 20 58 70 6C 69 63 6F 2D 4C 6F 67 73 74 61 73 68 2E vmwarevm\FOR572 Xplico-Logstash.
000002A0 76 6D 78 00 00 2D 00 44 00 3A 00 5C 00 45 00 51 00 55 00 49 00 50 00 53 00 5C 00 56 00 4D 00 73 vmx.-.D::\..E.Q.U.I.P.S.\.V.M.s
000002C0 00 5C 00 46 00 4F 00 52 00 35 00 37 00 32 00 20 00 58 70 70 00 6C 00 69 00 63 00 6F 00 2D 00 4C .\F.O.R.S.7.2. .X.p.l.i.c.o.-L
000002E0 00 6F 00 67 00 73 00 74 00 61 00 73 00 68 00 2E 00 76 00 6D 00 77 00 61 00 72 00 65 00 76 00 6D .o.g.s.t.a.s.h...v.m.w.a.r.e.v.m
00000300 00 28 00 00 00 09 00 00 A0 1C 00 00 00 31 53 50 53 E2 8A 58 46 BC 4C 38 43 BB FC 13 93 26 98 6D .(.....1SPSâSXFL8Cû..&"m
00000320 CE 00 00 00 00 00 00 00 00 60 00 00 00 03 00 00 A0 58 00 00 00 00 00 00 00 67 72 61 6E 61 64 61 f.....X.....granade
00000340 00 00 00 00 00 00 00 00 00 00 B4 7A 30 63 83 50 1F 47 A2 5B AC B0 2E B1 9A 14 D5 73 06 63 94 1D E6 .....zOcP.Go[-°.±š.Ös.c".e
00000360 11 82 EC 98 90 96 9A BC 02 B4 7A 30 63 83 50 1F 47 A2 5B AC B0 2E B1 9A 14 D5 73 06 63 94 1D E6 .,i~.-š%.zOcP.Go[-°.±š.Ös.c".e
00000380 11 82 EC 98 90 96 9A BC 02 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 .,i~.-š%.....
```


Artefactes Windows: Paperera

- És el lloc on s'emmagatzemen temporalment els fitxers eliminats
 - És possible eliminar un arxiu de forma "permanent" (sense que passi per la paperera de reciclatge) utilitzant la combinació de tecles Majús+Supr
 - Es pot configurar Windows per a que no utilitzi la paperera de reciclatge
 - La ubicació real de la paperera depèn de la versió de Windows que s'està utilitzant

Versión de Windows	Ubicación
Windows 95/98/ME (FAT32)	X:\RECYCLED
Windows NT/2000/XP (NTFS)	X:\RECYCLER\%SID%
Windows Vista/7+ (NTFS)	X:\\$Recycle.Bin\%SID%

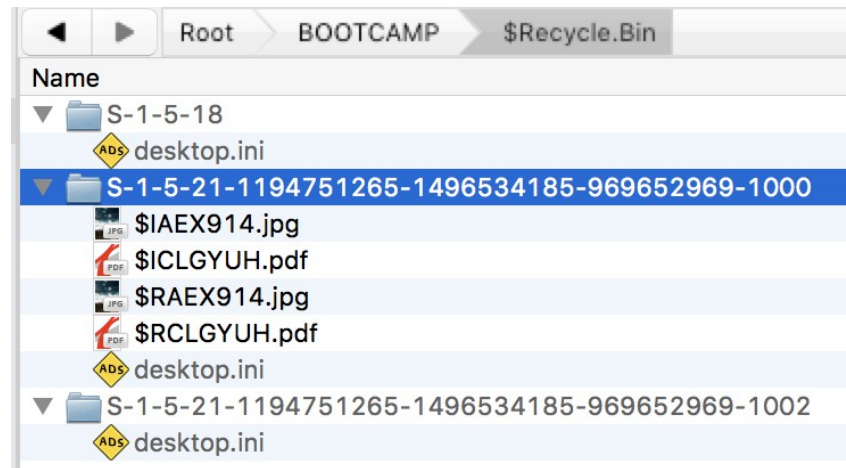
- Quan s'esborra un fitxer
 - S'esborra la entrada corresponent a la \$MFT
 - Master File Table: descripció de tots els fitxers d'un volum
 - Es crea una nova entrada per a la paperera a la \$MFT
 - D<letra><índex>.<Extensió_original>
 - Afegeix informació de l'esborrat a l'arxiu INFO2
 - Nom del fitxer original (path)
 - Data i hora de l'esborrat
 - Mida
 - Es pot analitzar el contingut de INFO2 amb programes específics com Rifiutiz de Intel/McAfee
- Quan es recupera un fitxer
 - L'entrada de la \$MFT de la paperera es marca com esborrada
 - No es modifica INFO2. Es canvia el primer caràcter a oox

Artefactes Windows: Paperera X:\RECYCLED (Windows 95/98/ME)

- Tot i que permetia tenir múltiples perfils d'usuari, tot era compartit entre tots
 - Cada usuari podia accedir a qualsevol arxiu
 - Inclòs modificacions de baix nivell (boot sectors, hard drive, etc.)
- De forma que només havia una paperera compartida entre tots els perfils
 - Paregut a Windows NT/2000/XP
 - Afegeix informació de l'esborrat a l'arxiu INFO (versió anterior de INFO2)
 - On s'emmagatzema la informació del fitxer original per a poder recuperar-lo

Artefactes Windows: Paperera \$Recycle.Bin (Windows Vista)

- Canvi a la paperera a partir de Windows Vista
- Els fitxers s'emmagatzema a un directori per cada usuari segons el seu SID
 - `X:\$Recycle.Bin\%SID%`
- Es creen 2 arxius per a cada arxiu eliminat
 - Les dades originals a un fitxer `$R<ID>`
 - Les metadades de l'arxiu eliminat a un fitxer `$I<ID>`



Artefactes Windows: Arxius Prefetch

- El prefetching d'aplicacions s'utilitza per a millorar el rendiment del SO des de Windows XP
- El sistema de monitorització de la cache de Windows escriu a disc certes característiques de les aplicacions executades
 - Directori protegit %SystemRoot%\Prefetch
 - Es creen fitxers amb la nomenclatura
 - <Nom_del_binari>-<hash_ruta>.pf
 - Cada binari executat des de rutes diferents tindrà fitxers PF diferents
 - Antigament el número de fitxers PF estava limitat a 128
 - Es poden utilitzar per a saber si s'ha executat un programa que ja no està instal·lat o ha sigut esborrat

Artefactes Windows: Arxius Prefetch

- Es pot analitzar utilitzant eines com
 - Windows File Analyzer, <http://mitec.cz/wfa.html>
 - NirSoft WInPrefetchView, <http://www.nirsoft.net/>
 - TZWorks Windows Prefetch Parser, <https://tzworks.net/prototypes.php>

Filename	Created Time	Modified Time	File Size	Process EXE	Process Path	Run Coun...	Last Run Time
IEEXPLORE.EXE-1B894A...	31/05/2016 19:35...	31/05/2016 17:26...	121.044	IEEXPLORE.EXE	C:\PROGRAM FILES\INTERNET EXPLORER\iex...	172	31/05/2016 17:26:24, 31/05/2016 14:14
IEEXPLORE.EXE-F6A52...	31/05/2016 19:35...	31/05/2016 18:45...	159.994	IEEXPLORE.EXE	C:\PROGRAM FILES (X86)\INTERNET EXPLOR...	266	31/05/2016 18:45:25, 31/05/2016 11:07
NOTEPAD.EXE-28E040...	20/05/2016 14:17...	20/05/2016 14:17...	26.816	NOTEPAD.EXE	C:\Windows\SysWOW64\notepad.exe	1	20/05/2016 14:17:53
NOTEPAD.EXE-EB1B9...	20/05/2016 13:47...	20/05/2016 14:17...	25.436	NOTEPAD.EXE	C:\Windows\System32\notepad.exe	2	20/05/2016 14:17:06, 20/05/2016 14:16

Filename	Full Path	Device Path	Index
\$MFT	C:\Windows\SysWOW64\msctf.dll	\DEVICE\HARDDISKVOLUME1\SMFT	28
0KG9FBEE.TXT	C:\USERS\...\APPDATA\LOCAL\MICROSOFT\WINDOWS\INETCOOKIES\LOW\0KG9FBEE...	\DEVICE\HARDDISKVOLUME1\USERS...	64
12CA52IY.TXT	C:\USERS\...\APPDATA\LOCAL\MICROSOFT\WINDOWS\INETCOOKIES\LOW\12CA52IY....	\DEVICE\HARDDISKVOLUME1\USERS...	252
1DAF2884EC4DFA96B...	C:\Users\manel\AppData\LocalLow\MICROSOFT\CRYPTNETURLCACHE\MetaData\1DAF2884...	\DEVICE\HARDDISKVOLUME1\USERS...	157
1DAF2884EC4DFA96B...	C:\Users\manel\AppData\LocalLow\MICROSOFT\CRYPTNETURLCACHE\Content\1DAF2884E...	\DEVICE\HARDDISKVOLUME1\USERS...	158
23B523C9E7746F715D...	C:\Users\manel\AppData\LocalLow\MICROSOFT\CRYPTNETURLCACHE\MetaData\23B523C9...	\DEVICE\HARDDISKVOLUME1\USERS...	228
23B523C9E7746F715D...	C:\Users\manel\AppData\LocalLow\MICROSOFT\CRYPTNETURLCACHE\Content\23B523C9E7...	\DEVICE\HARDDISKVOLUME1\USERS...	229
55E057BA572506A07A...	C:\Users\manel\AppData\LocalLow\MICROSOFT\CRYPTNETURLCACHE\MetaData\55E057BA...	\DEVICE\HARDDISKVOLUME1\USERS...	149

Artefactes Windows: Cua d'impressió

- Les tasques d'impressió es guarden al directori
 - %SystemRoot%\spool\PRINTERS
- Dos arxius temporals per a cada tasca:
 - Arxiu *.shd (Shadow)
 - Usuari, impressora, arxiu, mode d'impressió
 - Arxiu *.spl (Spool)
 - Informació gràfica de la tasca a imprimir
- Modes d'impressió: RAW, EMF (defecte)
 - EMF (Microsoft Enhanced Metafile)
 - Permet impressió avançada (p.e., tríptic)
- SPLViewer
 - Visualitza, imprimeix i guarda arxius de la cua

Artefactes Windows: Volume Shadow Copy (VSC)

- **Tecnologia** de Microsoft que permet realitzar còpies de seguretat d'arxius i volums en ús
- S'inclou per defecte a partir de Windows Vista / 7
- Es realitzen còpies de tipus instantània (snapshot):
 - Permet realitzar còpies totals o incrementals
 - Treballa a nivell de bloc realitzant una copia de seguretat si es detecta que es modificarà en una escriptura
 - És possible obtenir versions prèvies d'un arxiu, directori o volum a partir de una VSC
- Es poden analitzar
 - Online mitjançant la comanda `vssadmin.exe`
 - Des de imatges forenses utilitzant eines especialitzades

Artefactes Windows: Registre d'events

- Els registres d'events són arxius locals als que s'hi registren els diferents events que es produeixen al sistema operatiu
 - S'accedeix, s'esborra o s'afegeix un fitxer o una aplicació
 - Es modifica la data o s'apaga el sistema
 - Se canvia la configuració del sistema
 - etc.

Artefactes Windows: Arxius de registre d'events

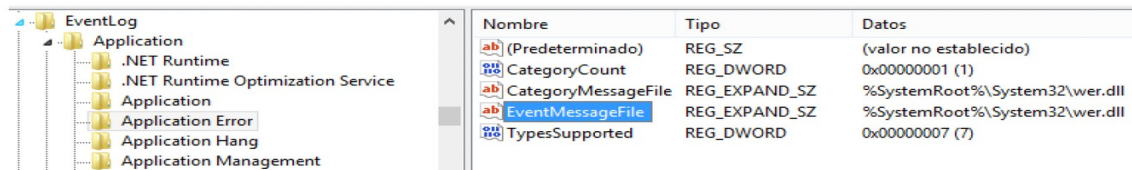
Antes de Windows Vista	Desde Windows Vista
C:\Windows\System32\config	C:\Windows\System32\winevt\Logs

- EventLog
 - Sistema
 - Seguretat
 - Aplicació
 - Format binari (*.evt)
- Windows EventLog
 - Sistema
 - Seguretat
 - Aplicació
 - + 200 arxius més
 - Format binari/XML (*.evtx)

Artefactes Windows: Registre de Windows

- El registre és la evolució dels fitxers *.ini i s'introduí per primer cop a Windows 95
- Es tracta d'una base de dades on les aplicacions i els components del sistema emmagatzemen i recuperen dades de configuració
- Les dades emmagatzemades al registre varien segons la versió de Windows
- Les dades es troben estructurades en arbre
 - Cada node de l'arbre es denomina clau
 - Cada clau pot contenir subclaus i dades, anomenades valors

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\EventLog



Nombre	Tipo	Datos
(Predeterminado)	REG_SZ	(valor no establecido)
CategoryCount	REG_DWORD	0x00000001 (1)
CategoryMessageFile	REG_EXPAND_SZ	%SystemRoot%\System32\wer.dll
EventMessageFile	REG_EXPAND_SZ	%SystemRoot%\System32\wer.dll
TypesSupported	REG_DWORD	0x00000007 (7)

Artefactes Windows: Claus predefinides

- El registre té 5 claus predefinides

Handle	Descripció
HKEY_CLASSES_ROOT	Tipus (o classe) de documents i les propietats associades
HKEY_CURRENT_CONFIG	Informació sobre el perfil de hardware actual de l'ordinador local. És un alias de: HKEY_LOCAL_MACHINE\System\CurrentControlSet\Hardware Profiles\Current
HKEY_CURRENT_USER	Preferències de l'usuari actual (que ha iniciat sessió). És un alias de: HKEY_USERS\<SID>
HKEY_LOCAL_MACHINE	Defineix l'estat físic de l'ordinador, memòria, software instal·lat, etc...
HKEY_USERS	Defineix la configuració per defecte per als usuaris (HKEY_USERS\ .DEFAULT)

Artefactes Windows: Claus d'interès

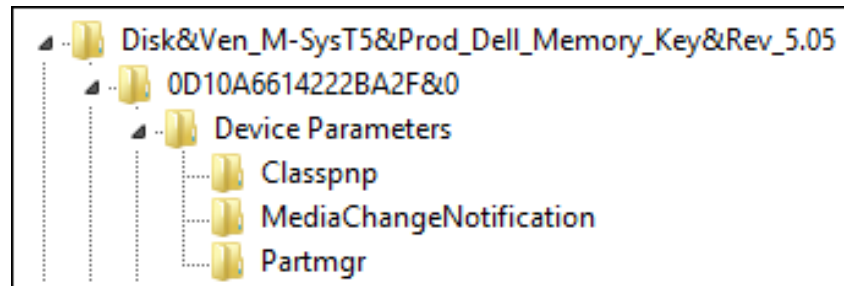
- Nom de l'ordinador
 - `SYSTEM\ControlSet00x\Control\ComputerName\ComputerName`
- BIOS (Fabricant, Model de l'equip, versió, etc.)
 - `HARDWARE\DESCRIPTION\System\BIOS`
- Processadors (Nom, Fabricant, Velocitat, etc.)
 - `HARDWARE\DESCRIPTION\System\CentralProcessor`
- Hora de la darrera aturada de l'equip
 - `SYSTEM\ControlSet00x\Control\Windows`
 - Valor "ShutdownTime"
- Programes d'inici
 - `SOFTWARE\Microsoft\Windows\CurrentVersion\Run`

Artefactes Windows: Claus d'interès

- Aplicacions registrades
 - SOFTWARE\RegisteredApplications
- Targetes de xarxa
 - SOFTWARE\Microsoft\WindowsNT\CurrentVersion\NetworkCards
- Xarxes de la Intranet (a les que s'ha connectat)
 - SOFTWARE\Microsoft\WindowsNT\CurrentVersion\NetworkList\Nla\Cache\Intranet
- Xarxes Wireless (identificadores)
 - SOFTWARE\Microsoft\WindowsNT\CurrentVersion\NetworkList\Nla\Wireless
- Perfils de xarxa (data de creació, connexió, etc.)
 - SOFTWARE\Microsoft\WindowsNT\CurrentVersion\NetworkList\Profiles

Artefactes Windows: Claus d'interès

- Impressores
 - SYSTEM\ControlSet001\Control\Print\Printers
 - El valor "PrinterDriverData" té informació sobre el model, el driver i la data d'instal·lació
- Dispositius USB
 - SYSTEM\ControlSet001\Enum\USBSTOR
 - Cada cop que es connecta un dispositiu USB es registra informació que permet identificar-lo de forma unívoca (fabricant, ID producte, número de sèrie, etc.)
- Històric
 - Clau "MRU", "Recent", etc. de diferents programes
 - Llista de URL introduïdes a Internet Explorer
 - Arxius recents de Word, Excel, Acrobat, etc.
 - Unitat de xarxa mapejada recentment
 - Comandes executades recentment, etc.



Artefactes Windows: Altres arxius de registre

- Windows guarda informació a fitxers de registre que pot ser útil analitzar

Arxiu	Descripció
setupact.log	Accions que s'han produït durant la instal·lació del sistema: hardware, arxius, etc.
setupapi.*.log	Instal·lacions, actualitzacions i dispositius connectats (USB, discos externs, etc.)
netsetup.log	Unió a un domini o grup de treball (Domini, comptes utilitzades, etc.)
pfirewall.log	Registre de paquets acceptats/descartats pel firewall de Windows (és necessari tenir-lo habilitat)
mrt.log	Registre de la eina Malicious Software Removal Tool (encarregada d'eliminar amenaces concretes)
cbs.log	Registre del gestor de paquets de Windows

Artefactes Windows: Arxiu SAM

- SAM (Security Account Manager) és una base de dades amb els hash de les contrasenyes i els usuaris
 - LM Hash
 - NTLM Hash (a partir de NT 3.1)
- Es troba a %windir%\System32\config
- No es pot accedir al fitxer SAM a un sistema en calent, és necessari fer-ho offline
 - Utilitzar bkhive per a bolcar la base de dades
 - `bkhive system /tmp/hive.txt`
 - I samdump2 per a bolcar els hash
 - `samdump2 SAM /tmp/hive.txt > /tmp/hash.txt`
 - Utilitzar John the Ripper, <https://www.openwall.com/john/>
 - `john /tmp/hive.txt --users=Administrator`

Artefactes Windows: NTFS ADS

- NTFS permet emmagatzemar informació addicional per a cada fitxer (metadades)
 - A partir de NT 3.1 per a proporcionar compatibilitat amb el HFS (Hierarchical File System) d'Apple
 - S'anomena Alternate Data Stream (ADS)
 - Aquesta informació addicional són arxius ocults enllaçats amb l'arxiu original (que no altera el seu format o contingut)
- Característiques
 - No hi ha limitacions de mida als streams
 - Poden haver més d'un stream enllaçat a un arxiu
 - Els ADS no són visibles a l'Explorador o a l'interpret de comandes (bé, una mica)
 - Els streams també es poden enllaçar a directoris i unitats de disco
 - El contingut pot ser binari (JPG, executable, etc.)
 - No es poden transferir utilitzant protocols d'Internet (HTTP, SMTP, etc.)
 - Però es poden transferir a través de la LAN si el disc de destí és NTFS

Artefactes Windows: Què més buscar?

- Directoris amb noms que comencen amb un punt
 - Solen ser directoris que mantenen paràmetres de configuració o informació sobre la instal·lació
- Arxius modificats recentment
- Arxius grans

Índex

- Introducció
- Aspectes legals
- Forensic Readiness
- Aspectes d'una investigació
- Adquisició d'evidències
- Artefactes
 - Windows
 - **Linux**

Artefactes Linux: Jerarquia del sistema de fitxers

- FHS (Filesystem Hierarchy Standard)
 - <https://wiki.linuxfoundation.org/lfsb/fhs-30>
 - 3.0 Juny 2015

Directori	Uso
/bin	Binaris essencials del sistema (link a /usr/bin)
/boot	Arxius d'arrencada (kernel i suport)
/dev	Dispositius
/etc	Arxius de configuració
/home	Arxius d'usuaris
/lib	Llibreries essencials i mòduls del kernel
/media	Muntatge de dispositius (automuntatge)
/mnt	Punts de muntatge temporals (muntatge manual)
/opt	Aplicacions fora dels paquets de la distribució
/sbin	Binaris del sistema amb requisits de superusuari
/tmp	Arxius temporals
/usr	Aplicacions gestionades per la distribució
/var	Dades variables de les aplicacions, per administració, logs, etc...

Artefactes Linux: Què se sol mirar?

- `/etc`
 - Equivalent a `%SystemRoot%\System32\config`
 - Directori principal de configuració del sistema
 - Arxius i directoris de configuració independents per a cada aplicació
- `/var/log`
 - Equivalent al Registre d'Events de Windows
 - Registres de seguretat, aplicació, etc.
 - Els registres es guarden durant 4-5 setmanes (depèn de la configuració)
- `/home/$USER`
 - Equivalent a `%USERPROFILE%`
 - Les dades i la informació de configuració de l'usuari

Artefactes Linux: Informació del sistema

Arxiu	Informació
/etc/*-release	Nom de la distribució Linux i la seva versió
/etc/hostname	Nom de l'ordinador (també es pot trobar als fitxers de /var/log)
/var/lib/dhclient /var/log/*	Direcció IP (DHCP)
/etc/localtime	Emmagatzema dades de la zona horària per defecte • Arxius binaris, s'ha d'usar zdump • Buscar a /usr/share/zoneinfo
/etc/passwd	Informació bàsica dels usuaris Els comptes amb UID=0 tenen permisos de 'root'
/etc/shadow	Hash SHA-256 de les contrasenyes (es pot usar John the Ripper)

Artefactes Linux: Informació del sistema

Arxiu	Informació
/etc/sudoers	Gestió del sudo per permetre elevació de privilegis
/etc/group	Mapping d'usuaris als seus grups
/var/log/wtmp	Mostra informació sobre de l'usuari, el seu origen, la hora i durada d'una sessió S'ha d'utilitzar la comanda <code>last</code> per poder verure'l
/var/log/btmp /var/log/faillog	Informació sobre els intents fallits d'accés (<code>last -f /var/log/btmp less</code>)
/var/log/auth.log /var/log/secure	Informació d'autorització del sistema, inclòs els inicis de sessió dels usuaris, els que no han tingut èxit i el mecanisme d'autenticació utilitzat
/var/log/daemon.log	Manté informació sobre els serveis en execució en background

Artefactes Linux: Informació del sistema

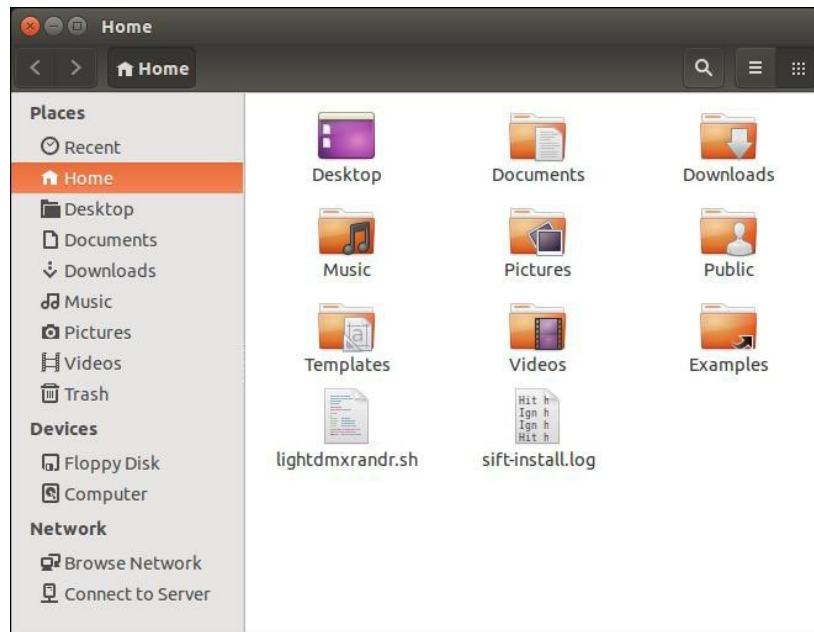
Arxiu	Informació
/home/<user>	La localització més habitual per als directoris i fitxers dels usuaris
/root	El directori de l'usuari root
/home/<user>/.*	Els fitxers i directoris "ocults" comencen per un punt • Contenen informació de configuració específica de les aplicacions • En alguns casos s'executen a l'iniciar sessió • És un possible backdoor o mecanisme de persistència

Artefactes Linux: Navegadors a Linux

- Firefox i Chrome són els més comuns a Linux
- Els formats dels fitxers són idèntics que a Windows
 - Base de dades SQLite
- Els fitxers solen estar als directoris dels usuaris
 - Firefox: `$HOME/.mozilla/firefox/*.default`
 - Chrome: `$HOME/.config/chromium/Default`

Artefactes Linux: Nautilus/Dolphin

- Són gestors de fitxers gràfics
- Tenen les miniatures a
 - `$HOME/.thumbnails`
- Arxius recents
 - `$HOME/.recently-used.xbel`
 - `~/.local/share/RecentDocuments`



Artefactes Linux: Històrics de comandes

- Les comandes executades per un usuari es guarden a
 - `$HOME/.bash_history` (bash)
 - `$HOME/.zsh_history` (zsh)
- La versió de bash no conté marques de temps per defecte
 - Es pot modificar amb la variable d'entorn HISTTIMEFORMAT:
 - `export HISTTIMEFORMAT='%F %T '`
- És fàcilment modificable per l'usuari
- L'històric de comandes sudo es pot trobar mirant els arxius
 - `/var/log/auth.log`
 - `/var/log/sudo.log`

Artefactes Linux: Secure Shell

- SSH és un protocol per permetre l'execució remota de comandes segura
- Permet
 - Iniciar una sessió remotament
 - Transferir fitxers a o des de un servidor
- Els fitxers més interessants per a investigar estan a `$HOME/.ssh`
 - **known_hosts**: màquines remotes a la que els usuaris s'han connectat
 - **authorized_keys**: claus públiques per a la connexió amb màquines remotes
 - **id_rsa***: claus privades utilitzades per a iniciar sessió a altres màquines sense utilitzar una contrasenya

Artefactes Linux: Què més buscar?

- Fitxers amb el setuid actiu
 - Permet a un usuari executar un programa amb permisos del propietari o del grup (setgid)
- Directoris amb noms que comencen per un punt
- Arxius normals al directori /dev
- Arxius modificats recentment
- Executables a llocs poc habituals (/tmp)
- Arxius grans

Seguretat Informàtica (SI)

Anàlisi Forense

René Serral (forked from: Davide Careglio)

Alguna font: Jordi Nin, “Network Security”, Computer Security, 2014

Ton Rodriguez, “Anàlisi forense”, Computer Security, 2018